



Российское
общество
Знание

Цифровая гигиена и личная безопасность в интернете

Севрюков С.Ю., СПбГУ

Предпосылки и проблематика



Желание получить
информацию/услугу/результат
быстро и просто

- Это причина и следствие цифровой трансформации

Первичность цифрового над
материальным

- Если раньше цифра была следствием или подспорьем материального, то в концепции Digital-first она стала первичной

Связь цифрового с
материальным

- Действия в цифровом пространстве могут отразиться на материальном

Различие между видимым
(человеко-читаемым) и
невидимым (машиночитаемым)

- Наше (человеческое) восприятие цифрового пространства и машины могут отличаться существенно

Проблемы и задачи

Информация может
иметь стоимость

- **Целостность**

Информация может
быть использована
против Вас

- **Конфиденциальность**

Секрет – это тоже
информация

- **Доступность**

Информационная безопасность защищает

Целостность

- Обеспечение достоверности и полноты информации и методов её обработки

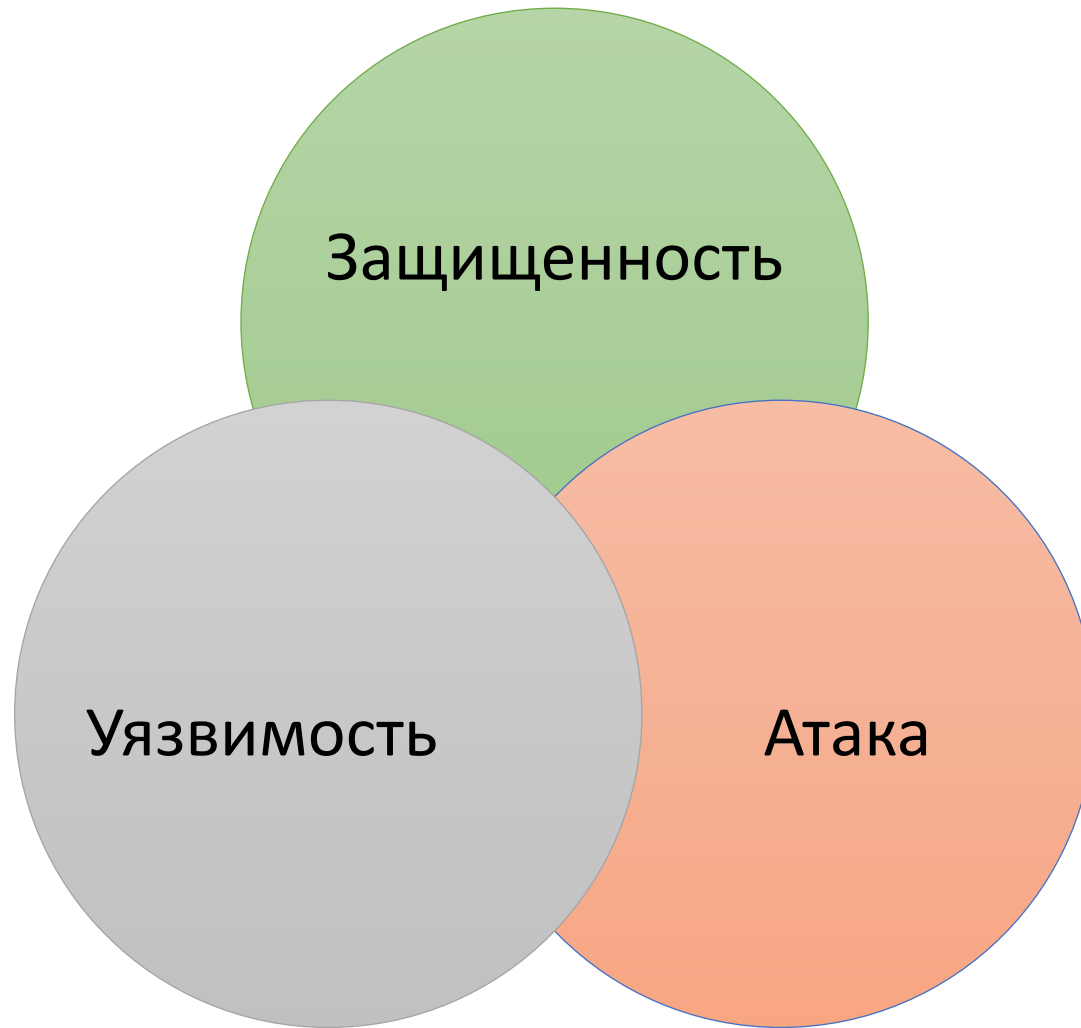
Конфиденциальность

- Обеспечение доступа к информации только авторизованным пользователям

Доступность

- Обеспечение доступа к информации и связанным с ней активам авторизованных пользователей по мере необходимости

Основные понятия информационной безопасности



Определения

Атака

- Любое действие нарушителя для реализации угрозы, путём использования уязвимостей

Уязвимость

- Любая характеристика или элемент системы, использование которой нарушителем может привести к реализации угрозы

Основные причины нарушения безопасности

Ошибки в программном и аппаратном обеспечении

Низкая квалификация участника информационного обмена (пользователя)

Непредумышленные действия участника информационного обмена (пользователя)

Умышленные действия злоумышленника

Категории нарушения безопасности



Перехват информации



Несанкционированный доступ



Нарушение целостности системы



Отказ в обслуживании

Достигая одной цели, мы уходим от другой



Для повышения
целостности и доступности
мы прибегаем к
избыточности (увеличение
узлов хранения данных)



С увеличением количества
узлов усложняется контроль
и обеспечение
конфиденциальности



Достигая одной цели, мы уходим от другой



Для повышения **целостности**
(и неизменности) данных мы
используем криптографию и
распределённую БД
(Blockchain)



Неизменность и
распределённость усложняют
(отменяют) возможность
скрытия или удаления
(**конфиденциальность**)



Современные технологии и ПДн

Машинное обучение и искусственный интеллект

- Извлечение ПД из неструктурированных данных

Смарт-контракты

- Данные участников и их действий

IoT (Интернет вещей)

- Данные владельцев и их окружения

Телемедицина

- Медицинские сведения пациента

Цифровая экономика

- Финансовая активность цифрового двойника

Несогласованность требований ИБ и 152 ФЗ

ИТ

- Распределённость
- Избыточность
- Криптостойкость

Законодательство ПД

- Ограничение доступа
- Локализация ПД
- Право на забвение

Стратегия злоумышленника как следствие психологии жертвы



Стратегия злоумышленника – за минимум усилий атаковать большинство жертв

- Автоматизация действий и её низкая стоимость
- Адаптивность для поиска оптимальной схемы

Для злоумышленника жертвой в Интернет является любой пользователь – атака на незнакомцев

Злоумышленник через Интернет атакует массово, адаптируясь под психологию и поведение большинства

- Т.е. если перестать быть большинством, то вероятность воздействия злоумышленника уменьшается, но не исчезает

Используемые злоумышленником факторы



Человеческий фактор

- Страх (потерять, пропустить, проиграть, уступить в социальном плане), доверие (позитивное мышление, помощь близким)
- Самоуверенность и невнимательность (утомлённость)

Технологический фактор

- Ошибки в оборудовании, ПО и конфигурации
- Низкая стоимость эксплуатации технических средств для атаки (доступность технологий)

Правовой фактор

- Уход от ответственности по причине разных юрисдикций
- Несовершенство нормативной базы и протоколов реагирования

Используемые злоумышленником средства



Средства обнаружения

- Сканеры и снифферы
- Использование открытых источников и парсеров
- Подделка беспроводных сетей

Средства манипулирования

- Звонки, СМС, Письма
- Сообщения в мессенджерах и социальных сетях
- Коммуникация в сервисах (например, в Avito), комментариях

Средства воздействия

- Зловредное ПО
- Временный или окончательный физический захват телефона
- Доступ к окружению (м.б. незаметно для пользователя)

Пример сканирования открытых источников



<https://github.com/sherlock-project/sherlock>

```
~/sherlock
$ python3 sherlock hackerman1337
[*] Checking username hackerman1337 on:

[+] 9GAG: https://www.9gag.com/u/hackerman1337
[+] AskFM: https://ask.fm/hackerman1337
[+] BitBucket: https://bitbucket.org/hackerman1337/
[+] Chess: https://www.chess.com/member/hackerman1337
[+] Codecademy: https://www.codecademy.com/profiles/hackerman1337
[+] Disqus: https://disqus.com/hackerman1337
[+] Docker Hub: https://hub.docker.com/u/hackerman1337/
[+] FortniteTracker: https://fortnitetracker.com/profile/all/hackerman1337
[+] Freesound: https://freesound.org/people/hackerman1337/
[+] GitHub: https://www.github.com/hackerman1337
[+] Instagram: https://www.instagram.com/hackerman1337
[+] Kik: https://kik.me/hackerman1337
[+] LeetCode: https://leetcode.com/hackerman1337
[+] Lichess: https://lichess.org/@/hackerman1337
[+] Minecraft: https://api.mojang.com/users/profiles/minecraft/hackerman1337
[+] OK: https://ok.ru/hackerman1337
[+] OpenStreetMap: https://www.openstreetmap.org/user/hackerman1337
[+] Pastebin: https://pastebin.com/u/hackerman1337
[+] Periscope: https://www.periscope.tv/hackerman1337/
[+] Pokemon Showdown: https://pokemonshowdown.com/users/hackerman1337
[+] Quizlet: https://quizlet.com/hackerman1337
[+] Redbubble: https://www.redbubble.com/people/hackerman1337
[+] Reddit: https://www.reddit.com/user/hackerman1337

[*] Search completed with 26 results

~/sherlock
$
```




Виды фишинга

- Фишинговые сайты
- Фишинговые письма, сообщения от фейков в мессенджерах
- Фишинговые мобильные приложения

Фишинг как средство обхода многофакторной аутентификации

- Запрос входа через «Госуслуги», фишинговая страница для ввода пароля и кода



Не переходить по ссылкам

- Помнить, что желание сделать что-то быстро и удобно (переход по ссылке) – это то, на что рассчитывает злоумышленник
- Открывать нужную страницу, набирая адрес
- Не переходить по ссылке рекламных объявлений в поисковой выдаче

Связь с отправителем по официальным каналам связи

- В ответ на поступившее сообщение - связаться по телефону и уточнить, направлялось ли сообщение
- Заодно отказаться от рассылки, если таковая не нужна

Фарминг

Набираете корзину в магазине

Переходите к оплате

Оплачиваете

Подвох в том, что из-за зловредного ПО, оплата производится злоумышленнику, а не магазину

- В ряде случаев злоумышленники подделывают магазины целиком

«Анонимность»



Средства анонимизации (например, VPN сервисы) используются злоумышленниками как приманка и средства кражи передаваемых данных, включая ключи

Фактически, анонимность декларируется, но не обеспечивается

Сценарий: шантаж под предлогом сохранения анонимности

Мессенджеры как новый канал воздействия



Подделка аккаунтов

Взлом пабликов

- От имени автора канала прямо в паблик поступает предложение-запрос о донате

Боты как сборщики данных и информации (чекеры, чатботы)

- Предложения проверить утечку персональных данных и аккаунтов (путём их передачи боту)
- Чатботы с искусственным интеллектом, мотивирующие передавать документы и фото (для их интеллектуальной обработки)



Дипфейки

- Технологии синтеза голоса и внешности (включая видео)

Персонализация и автоматизация диалогов

- Пример использования больших языковых моделей

Сбор данных, передаваемых чатботам и сервисам на базе ИИ (проводим аналогию с VPN)

Перестаём быть большинством



Человеческий фактор

- Саморефлексия, критическое мышление
- Внимание против самоуверенности
- Укрепляем окружение (улучшаем защиту близких)

Технологический фактор

- Обновления и проверка оборудования и ПО
- Использование технических средств защиты

Правовой фактор

- Соблюдение норм и правил
- Информирование специалистов и органов об инцидентах

Информационная гигиена как прототип и основа цифровой



Проблематика

- Не определены информативность и польза информации для субъекта
- Фрагментарность информации
- Замена активных действий (поиск информации) пассивным потреблением («прослушивание персонального эфира»)
- Замена фактов оценками, удаление или пересмотр контекста

Профилактика и гигиена

- Определять цель получения информации
- Нормировать объём поступающей информации
- Фильтровать источники, отказ от непредсказуемых по содержанию подписок в пользу тематических

Технические средства защиты



Приватный режим работы браузера

Использование мобильных приложений вместо сайтов (например, для онлайн-банка или магазинов)

Надёжные пароли (менеджер паролей) и политики обновления

Многофакторная аутентификация

Базовые средства защиты (антивирус и сетевой экран)

Наши близкие – наша брешь и наш бастион



Наши дети ничего не знают об атаках точно так же, как о болезнях

- Дети не обращаются с проблемами, если они не видят поддержки или чувствуют угрозу (наказание за ошибку вместо помощи)
- Для детей проблемы в виртуальном мире столь же виртуальны
- Если поставить себе цель «обеспечить безопасность ребёнка», то повысишь безопасность и себе

Старшее поколение нуждается в нашей помощи

- Помощь в освоении новых сервисов и средств

Избирательность в интернет-связях

- Отказ от излишней коммуникации
- Запрет на использование адресной книги
- Закрывание публичного доступа к профилю



Отраслевая концепция нулевого доверия (Zero trust) может помочь в обеспечении безопасности и обычным пользователям

- Представьте себя как предприятие и владельца ресурсов, а всех остальных – потенциальными пользователями
- Определите строгий минимум тех, кто должен иметь доступ
- Сформируйте и используйте надёжные средства доступа (например, общий секрет)
- Следите за активностью

Отработка сценариев реагирования

- Что я буду делать, если лишусь телефона (карты, доступа и т.д.)



Информационная гигиена как ключ к цифровой

Избирательность в сервисах и средствах

Применение технических средств защиты

Работа с близкими

Нулевое доверие

Рекомендуемые ресурсы



1. Книга «Цифровая гигиена», Игорь Ашманов, Наталья Касперская, 2022, [ISBN: 978-5-4461-1938-7](#)
2. [Кибербезопасность: Онлайн-лекция](#)
3. Раздел на сайте Сбера: [Киберзащита для всей семьи](#)
4. [Яндекс DNS](#): Быстрый и безопасный домашний интернет
5. [Видео: Техника безопасности в интернете, как бороться с кибератаками](#)
6. [Видеоуроки от Киберпроект](#)
7. [Курс для образовательных учреждений от Киберпроект \(требуется регистрация на платформе\)](#)
8. [Видео: Мастер-класс по цифровой гигиене – навыку безопасного и рационального поведения в сети](#)
Ведущий: Игорь Ашманов – канд. тех. наук, президент АО «Крибрум»,
президент ГК «Ашманов и партнеры»,
заведующий кафедрой «Цифровая социология»
Высшей школы современных социальных наук МГУ им. М.В. Ломоносова
9. [Примеры социальной инженерии: «Социальная инженерия глазами жертвы»](#)
10. [Пример плана: Что делать, если потерял телефон?](#)
11. [Концепция безопасности Zero Trust: преимущества и принцип работы](#)

Остались вопросы?



s.sevryukov@spbu.ru